

Data Safety: Masking, Redaction, Minimization

Chapter 09 · Episode 01 · Domain 2.6 — Reduce What Exists

Upstream Beats Downstream

MINIMIZATION

Reduces what is collected

Absent data cannot leak

ENCRYPTION

Protects what remains

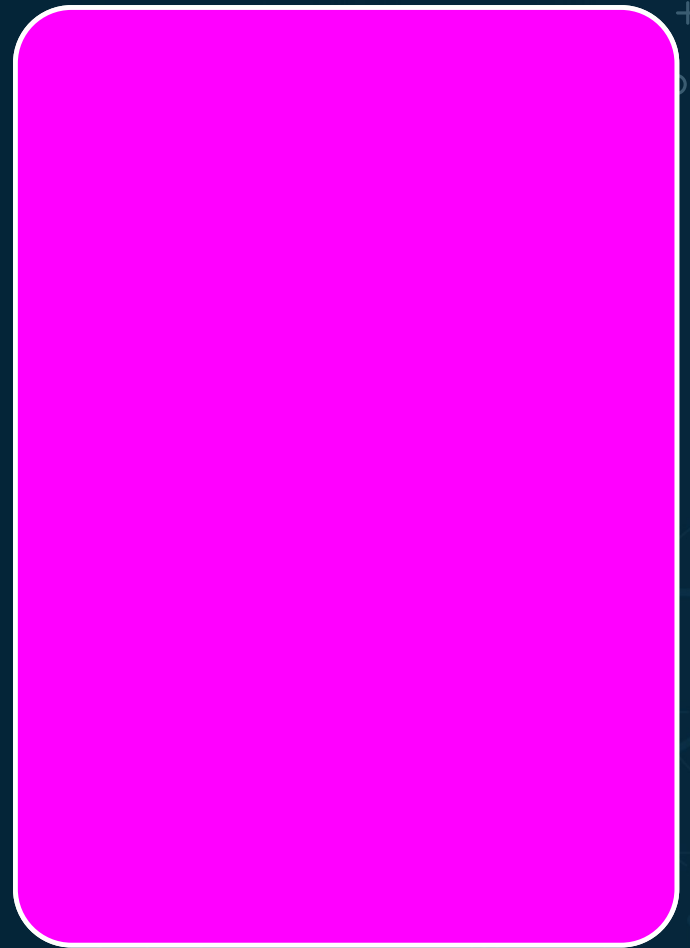
Applies after collection

Classification Drives Handling

Public · internal · confidential · restricted

Label training data by tier

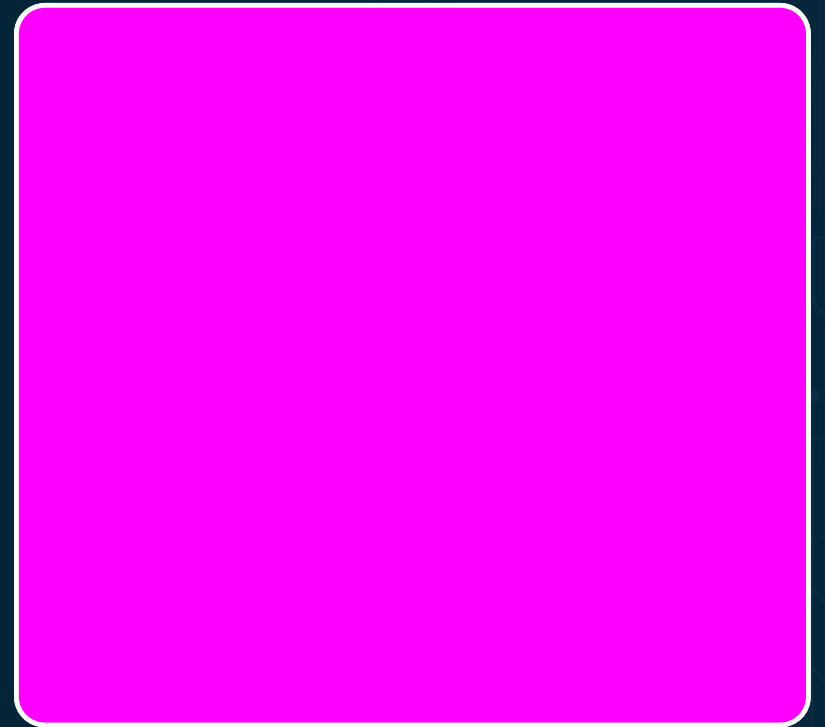
Segment retrieval corpora at ingestion



Classify at Ingestion — Never After

Unlabeled regulated data = policy failure

Labels drive every downstream control



Masking & Redaction Techniques



STATIC

Permanent,
irreversible alteration



TOKENIZE

Reversible token +
separate key map



DYNAMIC

Runtime-only hiding —
storage intact



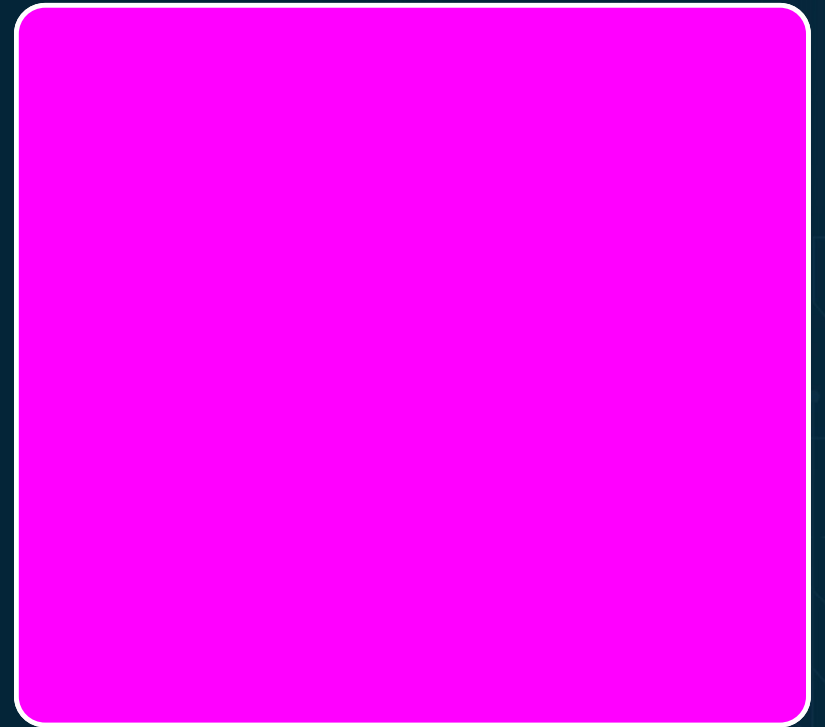
REDACT

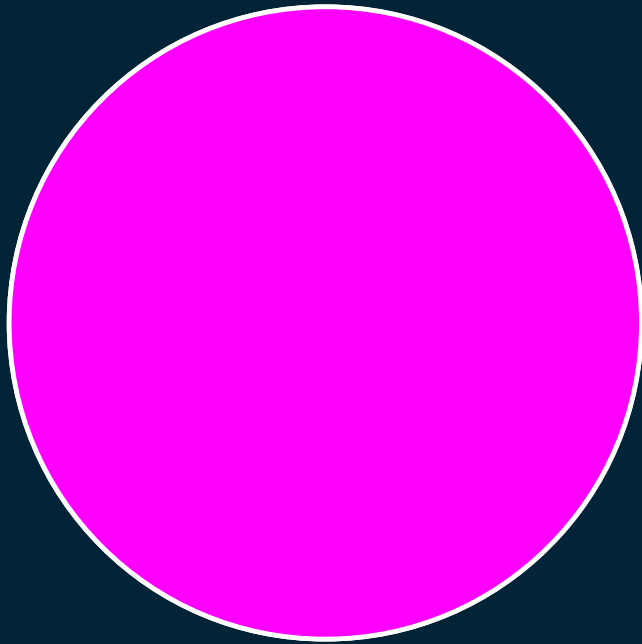
Removed entirely
before ingestion

Redaction Removes — Masking Obfuscates

Static permanent · dynamic runtime-only

Tokens reversible — redaction is gone





Data Minimization

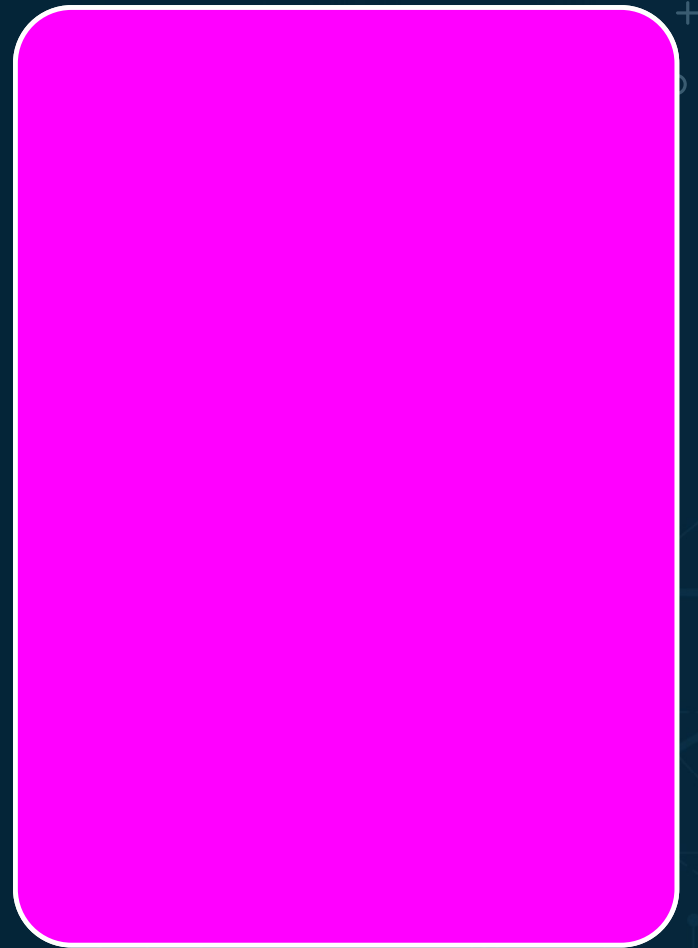
1. Collect only what the purpose requires
2. Metadata may suffice — not identifiers
3. Retention limits stop accumulation
4. Purpose-bound — no silent repurposing

Accumulation Is Exposure

Old data: stale consent, weaker controls

No retention limit = violated principle

Shorter retention → smaller breach area



Validate Data Safety Controls



AUDIT

Masking vs evolving
extraction methods

DETECT

Unclassified sensitive
data at ingestion

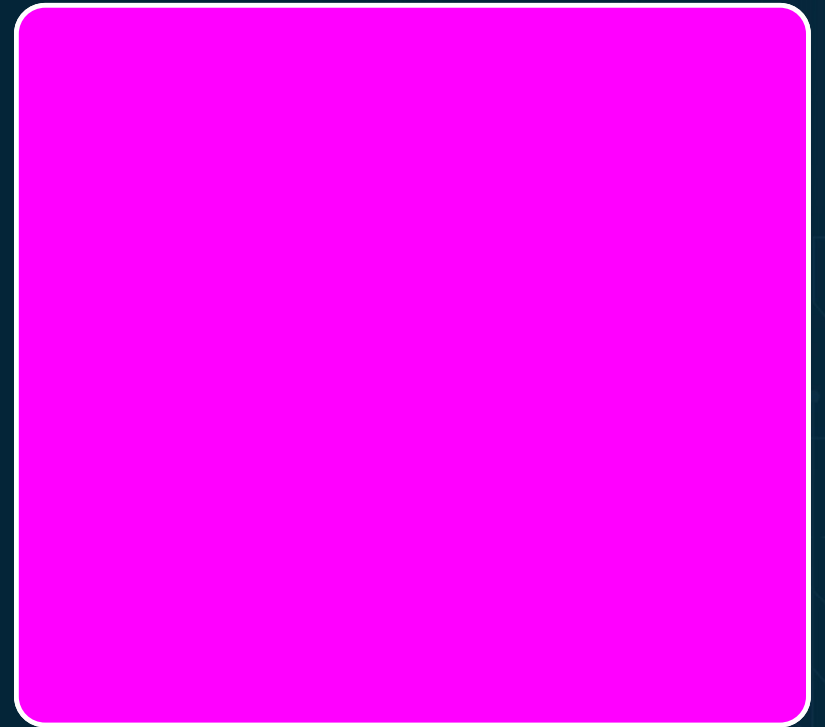
REVIEW

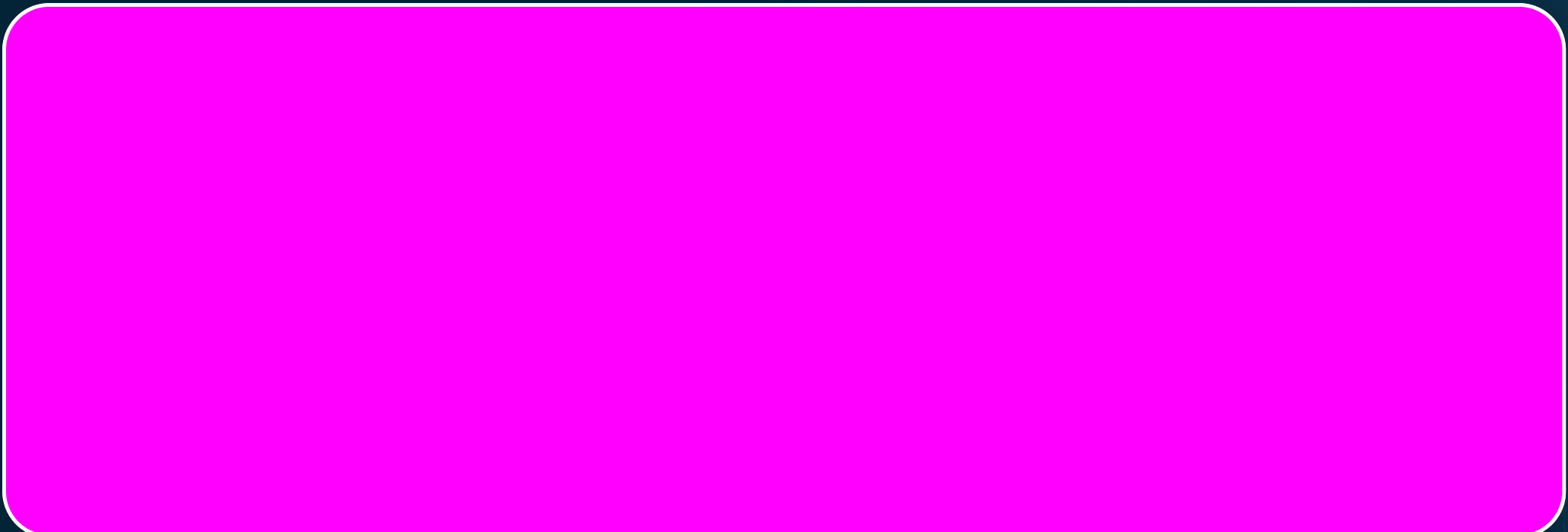
Retention + redaction
enforced in practice



Controls Claimed $\neq$ Controls Working

Drift + misconfigs silently add exposure
Minimization decides what remains at all





Demo: Data Safety Pipeline

Colab audit — classification, masking, tokenization, retention

Episode Takeaways

Minimization reduces what exists — encryption protects what exists

Static = permanent · dynamic = runtime · token = reversible · redact = removal

Classification at ingestion — retroactive labeling fails

Governance monitoring catches drift and masking failures

Data Integrity and Output Protection

Chapter 09 · Episode 02 · Domain 2.6 — Authentic and Unaltered

Integrity vs Confidentiality

STOLEN DATASET

Serious — but the theft is visible

SILENT ALTERATION

Invisible until decisions shift

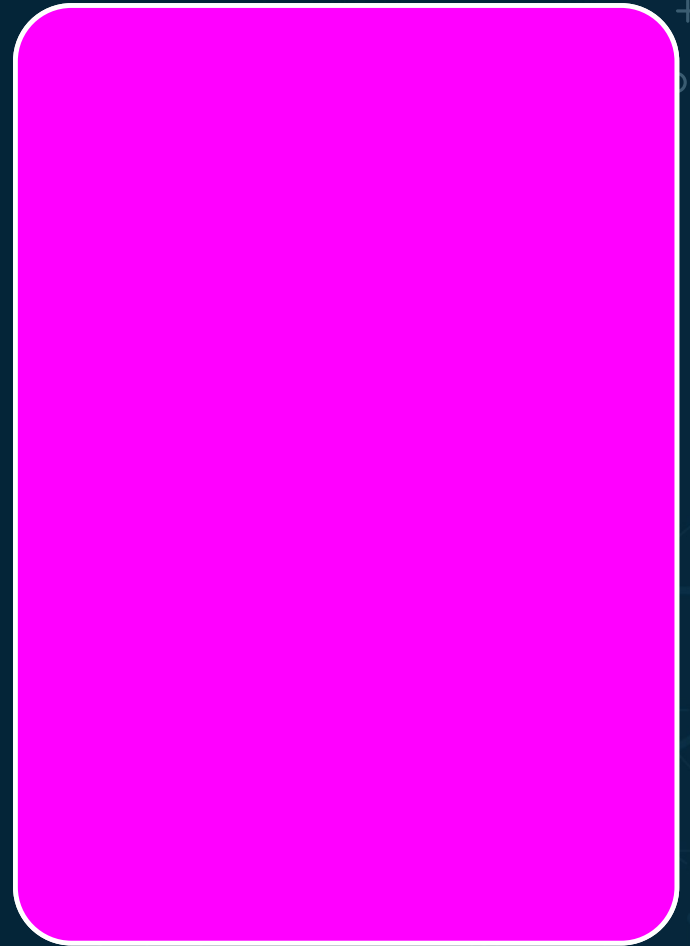


Every Transition Can Alter

Ingestion → training → inference → logs

Modified logs break forensics

Odd behavior? Suspect integrity first



Stored-Data Integrity

HASH

Any change flips
the fingerprint

IMMUTABLE

Write-once or
append-only

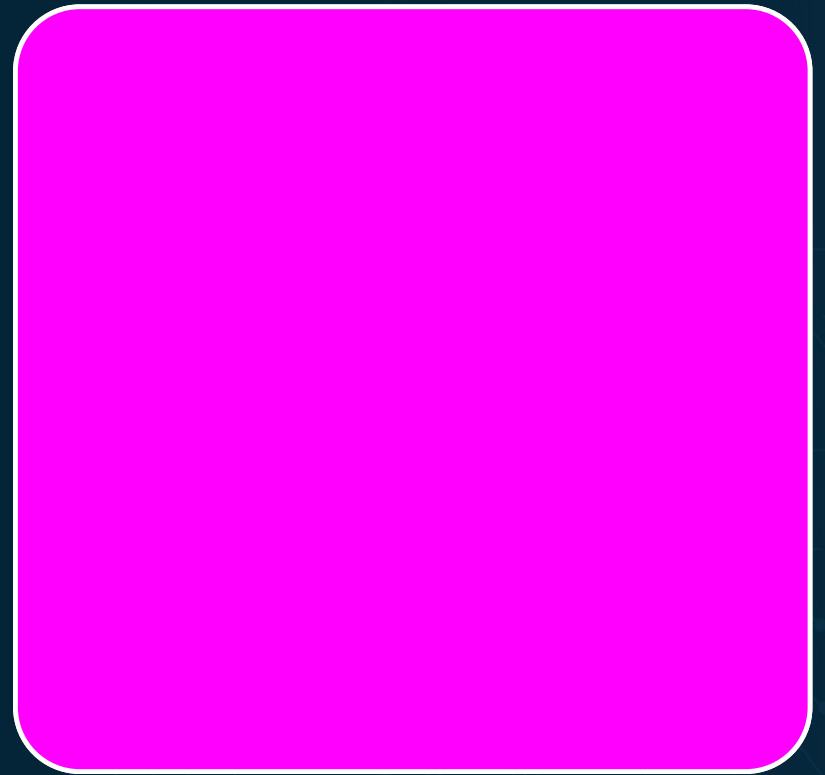
DETECT

Alerts on
unexpected change

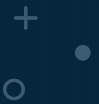
VERSION

Reproducible
dataset states

Preserve original state for forensic retraining



Protect Outputs and Logs



VALIDATE

Verify outputs
before users act



SIGN

Signatures prove
origin + tampering



LOG

Append-only ·
timestamped · verifiable



HANDOFF

Every system hop
can alter output

Prove Origin and Authorship



WATERMARK

Embedded patterns verify
generated output

PROVENANCE

Dataset origin + training
lineage records

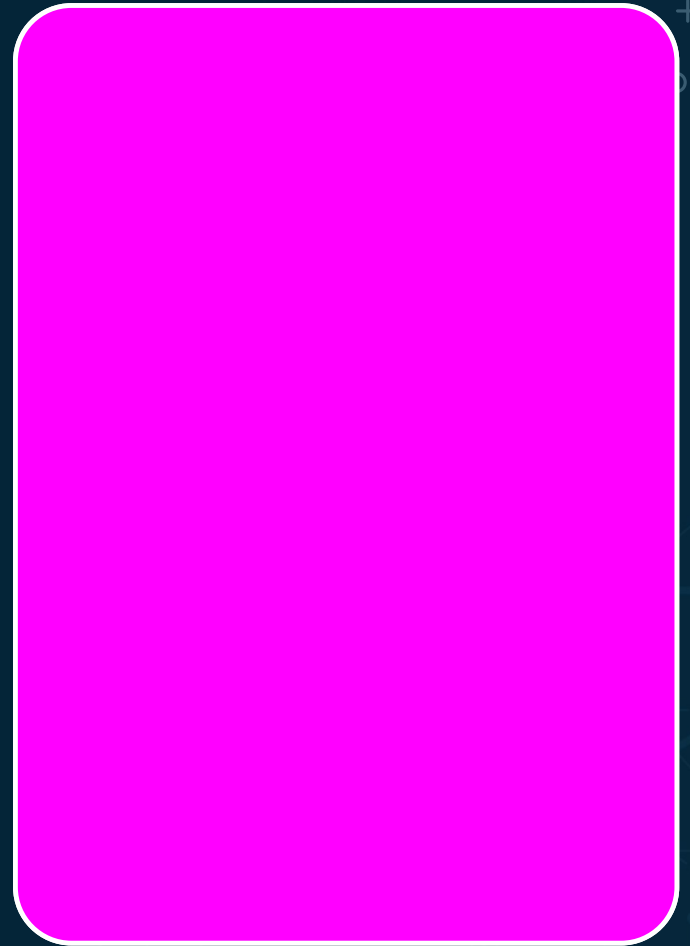
AUTHENTICITY

Recipients confirm
a trusted source



Drift Without a Cause?

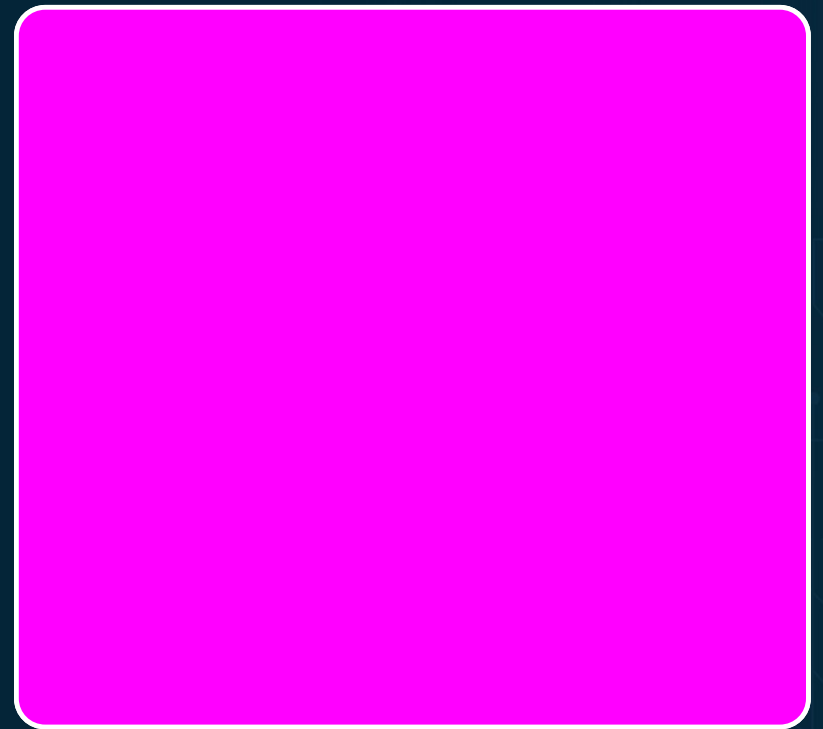
Unexpected drift may be tampering
First hypothesis: integrity compromise
Monitor continuously, not just at setup

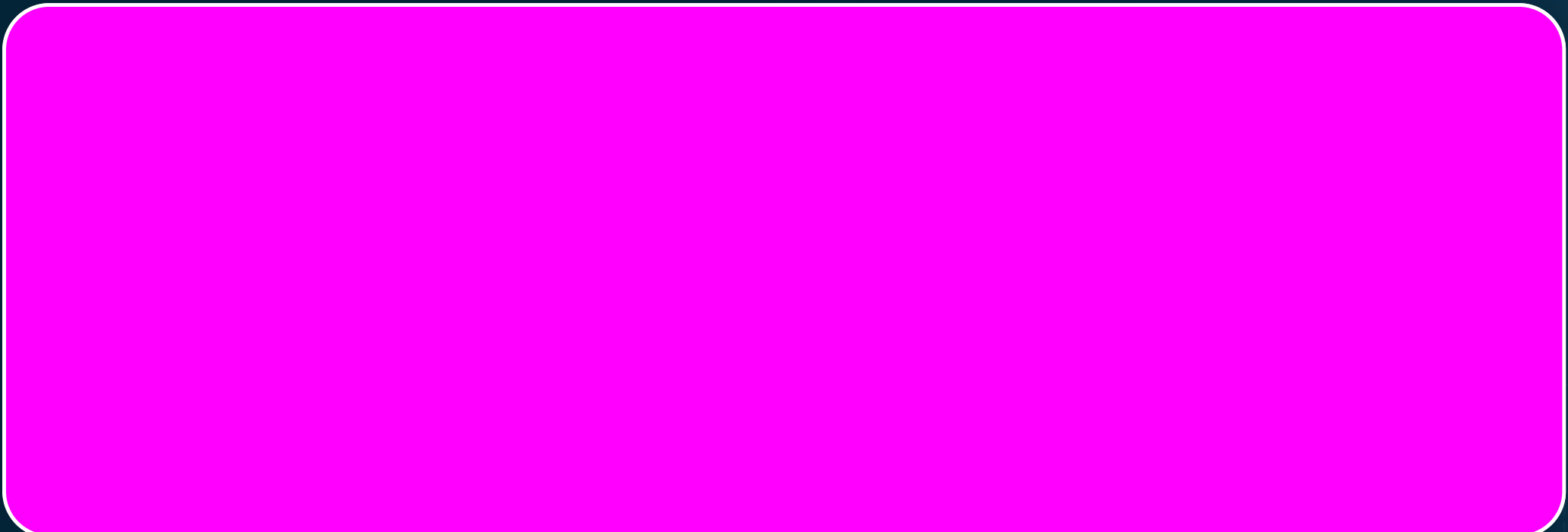


Detection Without Restoration Fails

Roll back to verified known-good states

Alerts must trigger containment





Demo: Integrity Verification

Hashing, append-only logs, signatures, provenance, rollback

Episode Takeaways

Silent modification = integrity failure — worse than theft

Hashing is the primary dataset integrity check

Logs: append-only + timestamped + verifiable

Watermark origin · provenance lineage · rollback restores

Prompt Monitoring, Logging, and Telemetry

Chapter 09 · Episode 03 · Domain 2.6 — Make Hidden Abuse Visible

Two Signals in the Telemetry

INJECTION

Repeated override-language variants

EXTRACTION

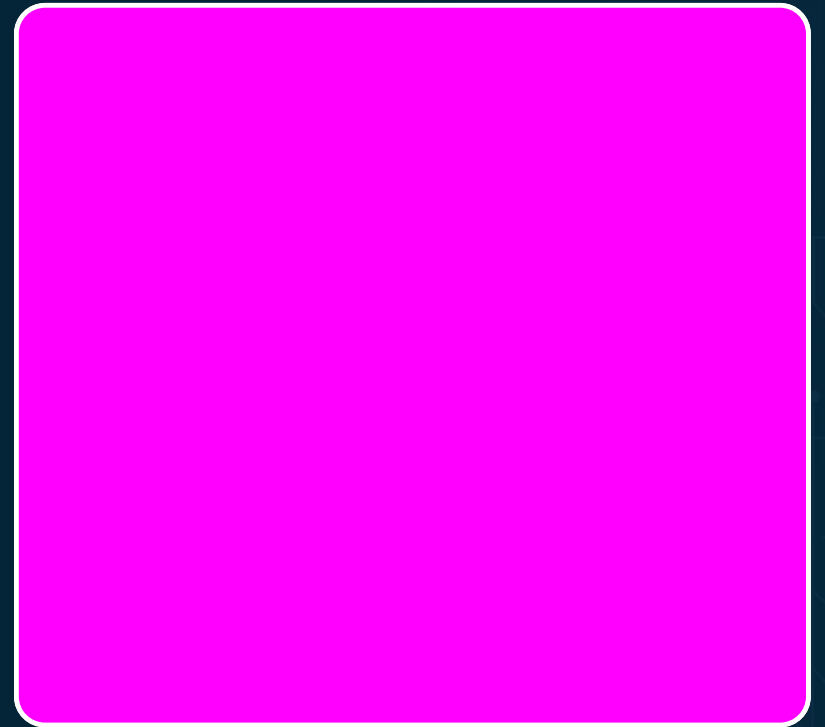
Structured high-frequency probing



Monitoring Is a Detective Control

Turns hidden abuse into visible events

Structured logging is the baseline



The Telemetry Package

PROMPT

Full or redacted content

METADATA

Tokens, size, frequency

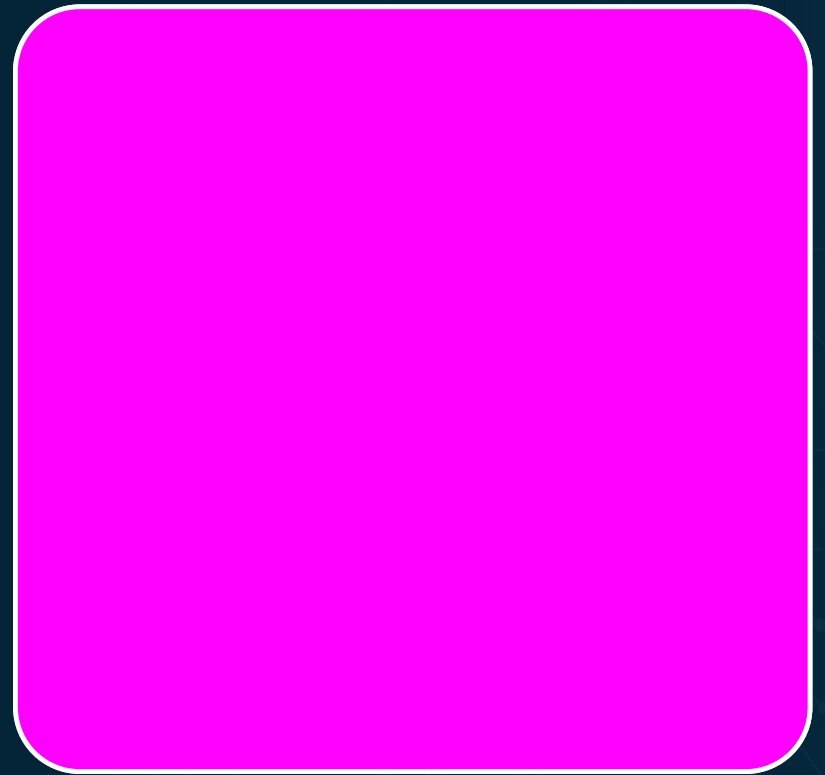
RESPONSE

Output + confidence scores

IDENTITY

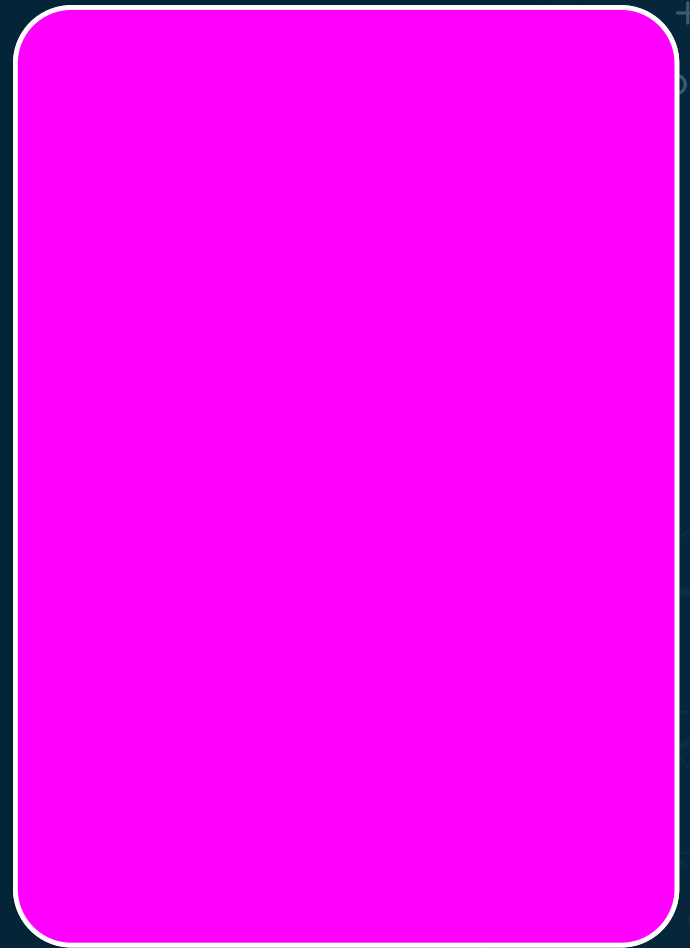
User, auth method, session

Timestamp + model version + region = forensic backbone



Logs Carry Sensitive Data

Protect prompt logs like source data
Investigative value vs privacy duty



The Anomaly Detection Trio

BASELINE

Expected length, rate,
timing per role

FREQUENCY

Volume spikes →
extraction or bots

PATTERN

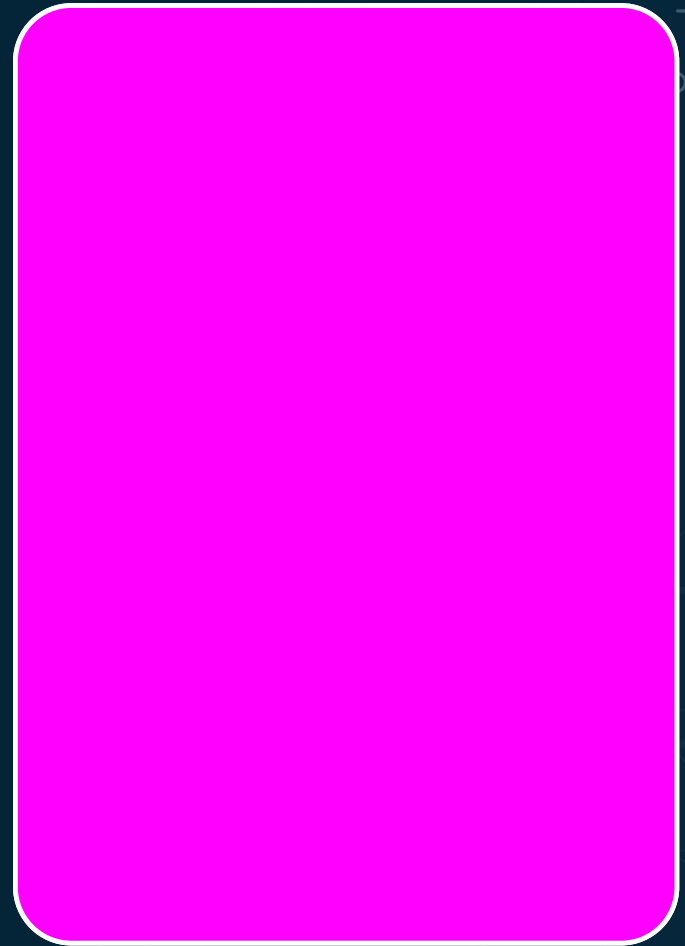
Repeated override
phrasing variants

Beyond Static Thresholds

Confidence swings = adversarial pressure

Cross-user ties reveal coordination

Know all three trio components



Plug AI Into the SOC



AGGREGATE

Prompt logs flow
into the SIEM



PRIORITIZE

Rank alerts — stop
analyst fatigue



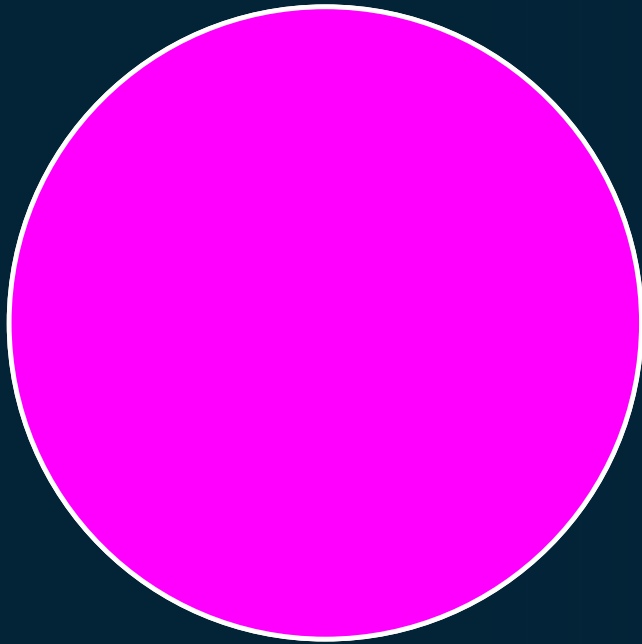
CORRELATE

Tie AI events to
identity signals



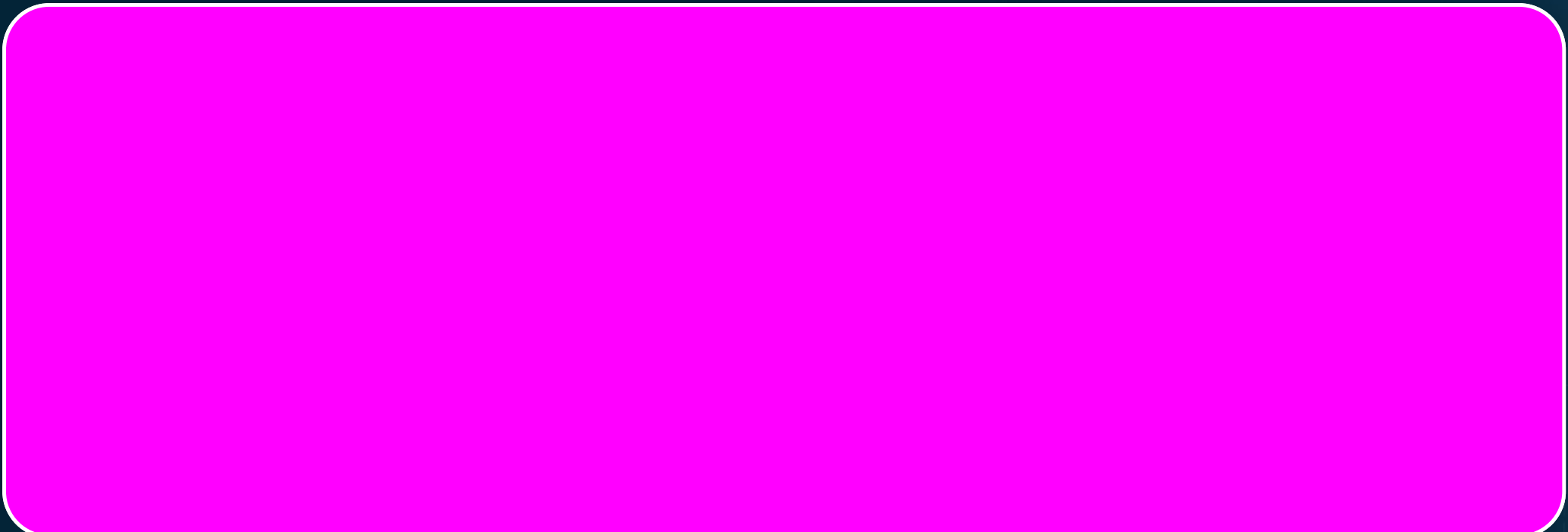
RESPOND

Defined escalation
+ containment



Lawful Logging

1. Redact sensitive fields before storage
2. Retention caps — stale logs add risk
3. Access limited to authorized reviewers
4. Align with data protection law



Demo: Live Prompt Telemetry

GPT-4o mini — capture, anomaly detection, privacy redaction

Episode Takeaways

Detective control — makes hidden abuse observable

Full package: prompt + metadata + response + identity + time

Baseline + frequency + pattern = anomaly detection

Telemetry joins the SIEM — uncontrolled logging is risk



AI Cost Monitoring and Resource Abuse

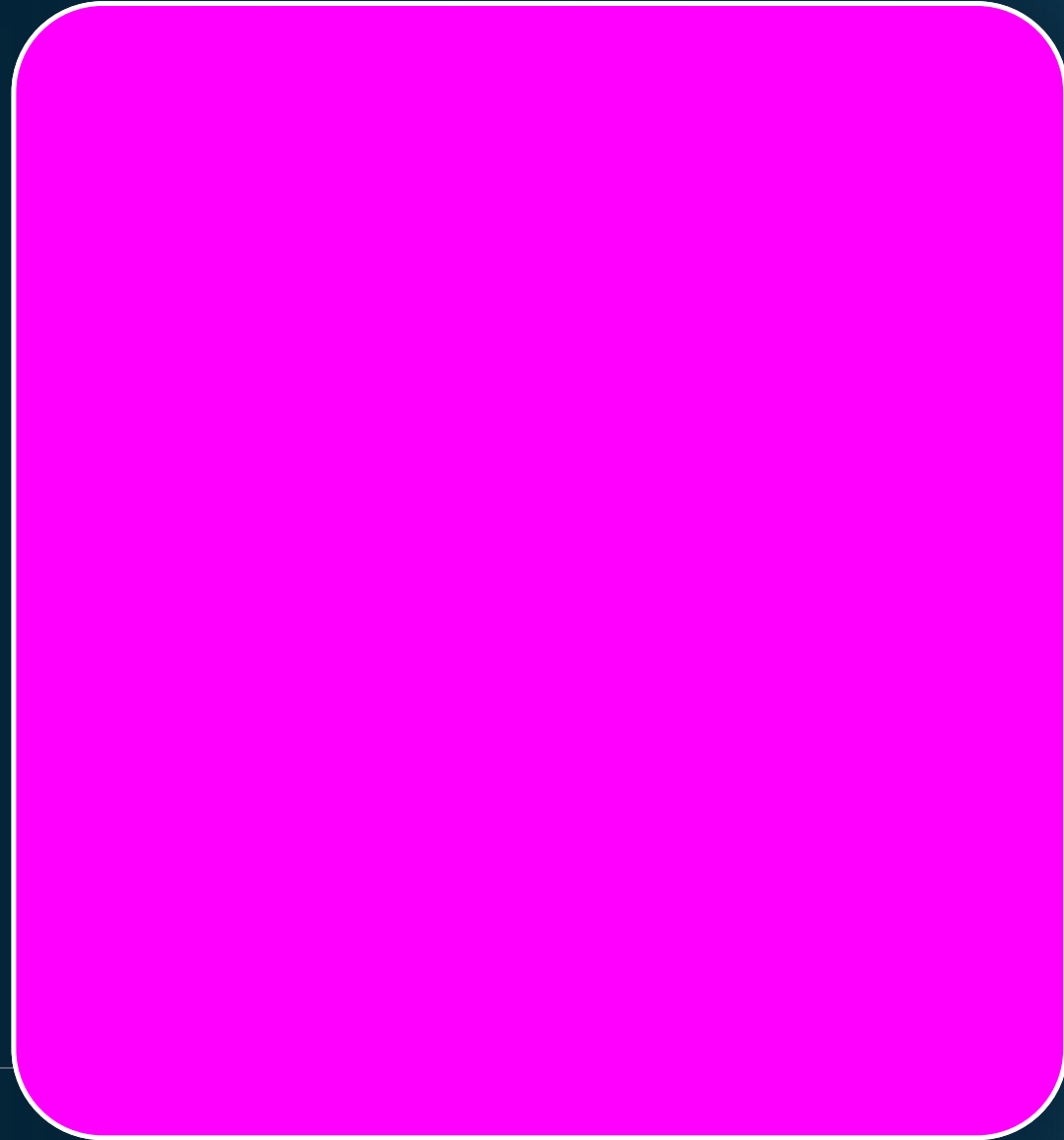
Chapter 09 · Episode 04 · Domain 2.6 — Economic Denial of Service

The Economic Attack Surface

Token billing = attackable cost curve

High-volume requests inflate spend

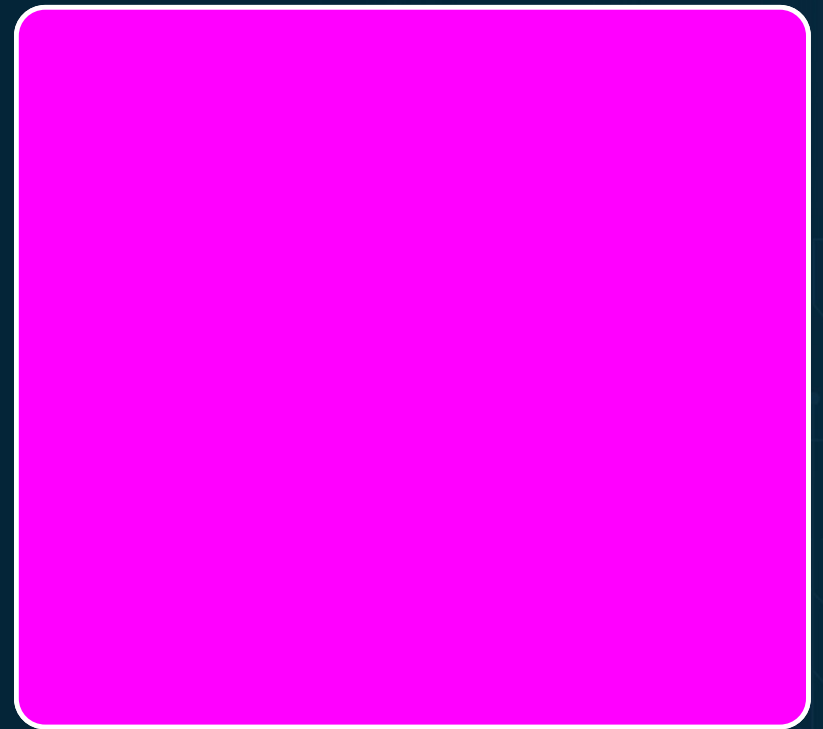
No breach needed — purely economic



When Cost Abuse Delays Detection

Slow AI responses, slow incident response

Cost monitoring is a security control



Token Monitoring: Two Modes

PREVENTATIVE

Ceilings block oversize requests

DETECTIVE

Trend analysis flags odd growth



Spotting Automated Abuse



SPEED

Machine-pace
request intervals



BOT-LIKE

Rapid follow-ups
probe prior output



FINGERPRINT

Timing, token
structure, parsing



EVASION

Volume abuse
inside rate limits



Beyond Token Counts

COMPUTE

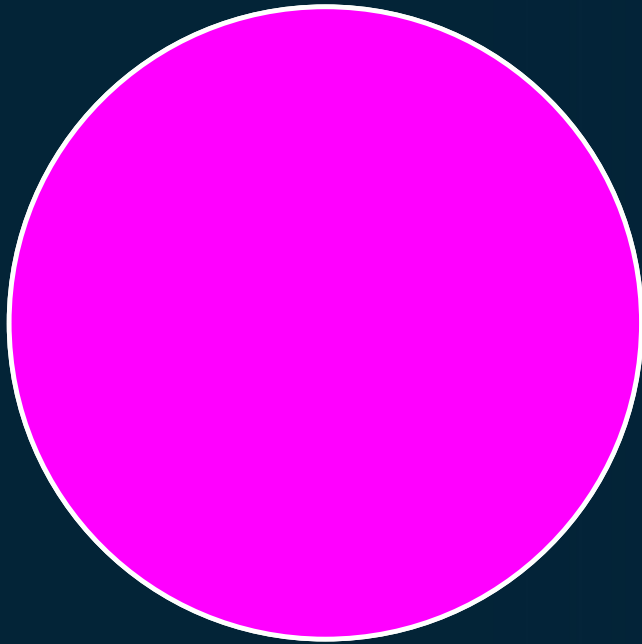
GPU saturation flags
adversarial load

STORAGE

Dataset + embedding
growth watched

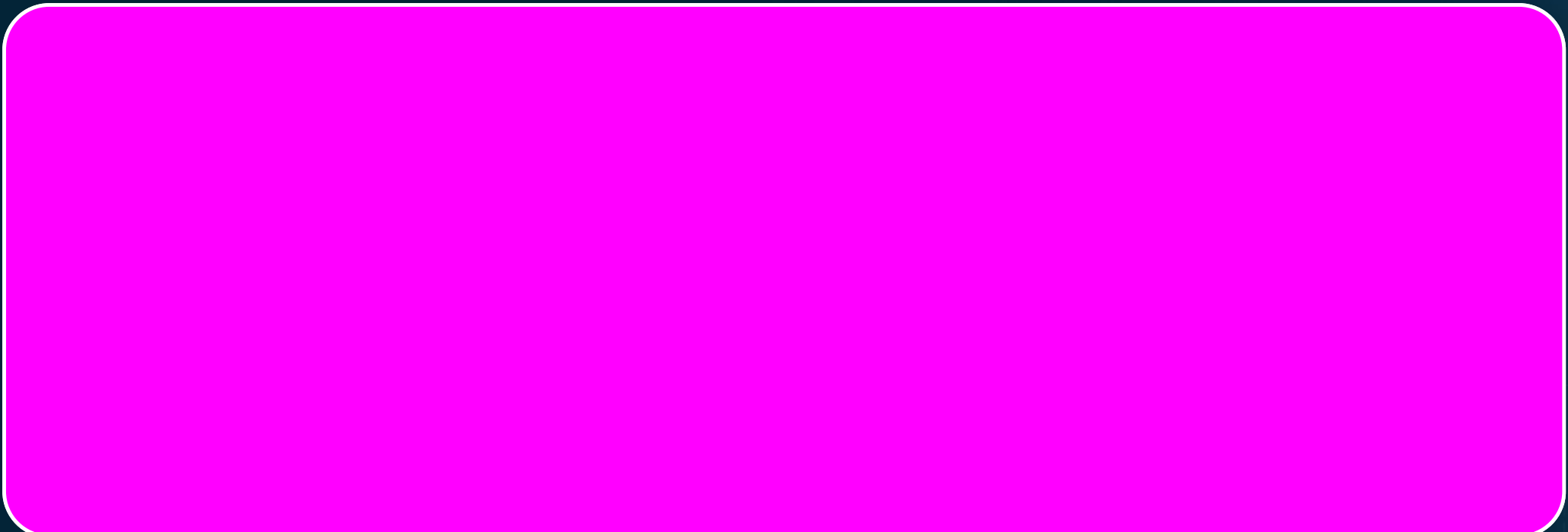
CORRELATE

Tie spikes to identities
and endpoints



Wire Alerts to Action

1. Alert thresholds trigger investigation
2. Throttle dynamically during abuse
3. Post-incident cost analysis refines policy
4. Route to security AND finance



Demo: Resource Abuse Pipeline

Token quotas, cost anomalies, fingerprinting, correlation

Episode Takeaways

Economic DoS — real damage, no data theft

Token controls: preventative ceilings + detective trends

Behavioral detection closes the rate-limit gap

Correlate spikes to identities, not aggregates



AI Cost Monitoring and Resource Abuse

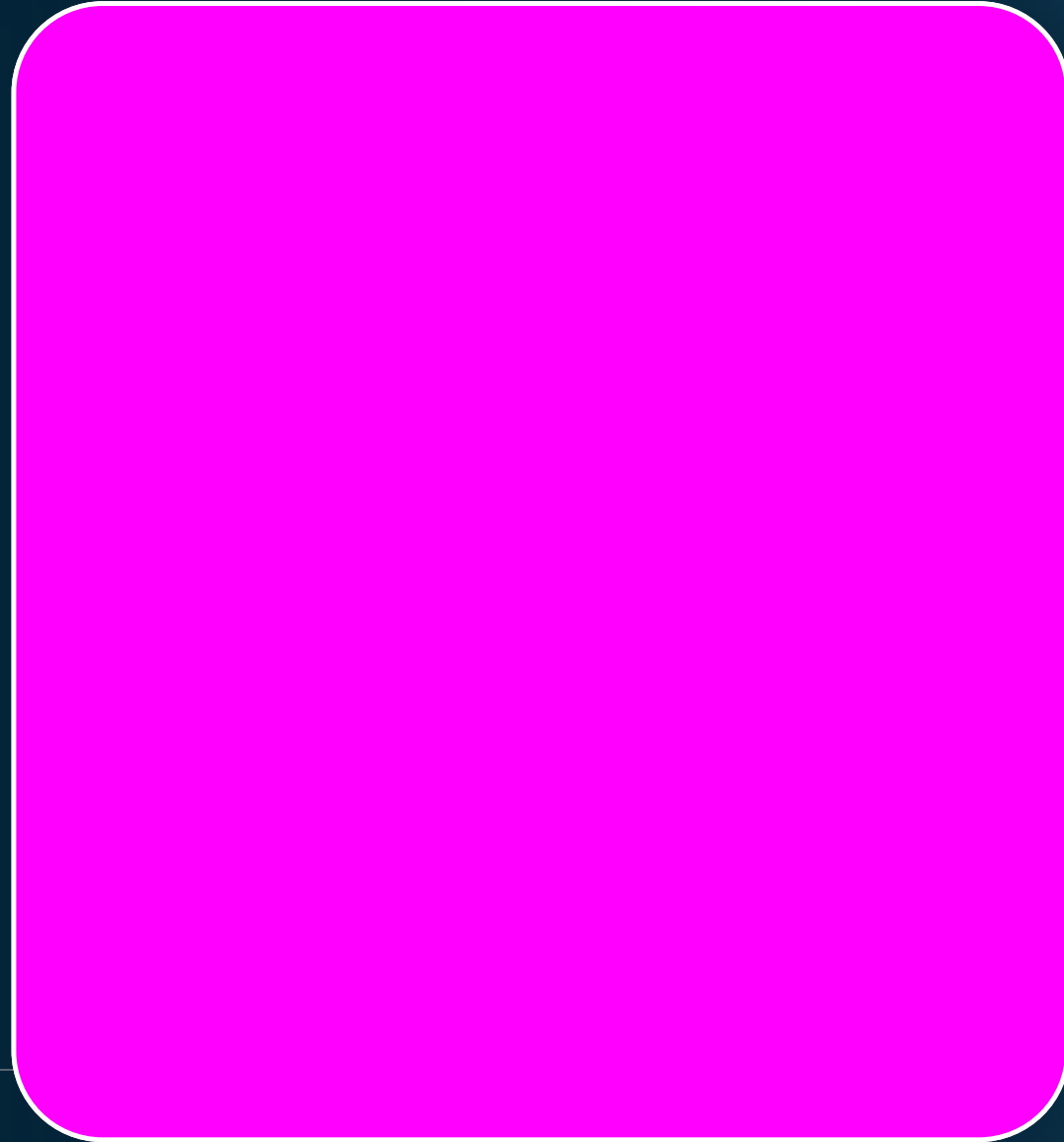
Chapter 09 · Episode 04 · Domain 2.6 — Economic Denial of Service

The Economic Attack Surface

Token billing = attackable cost curve

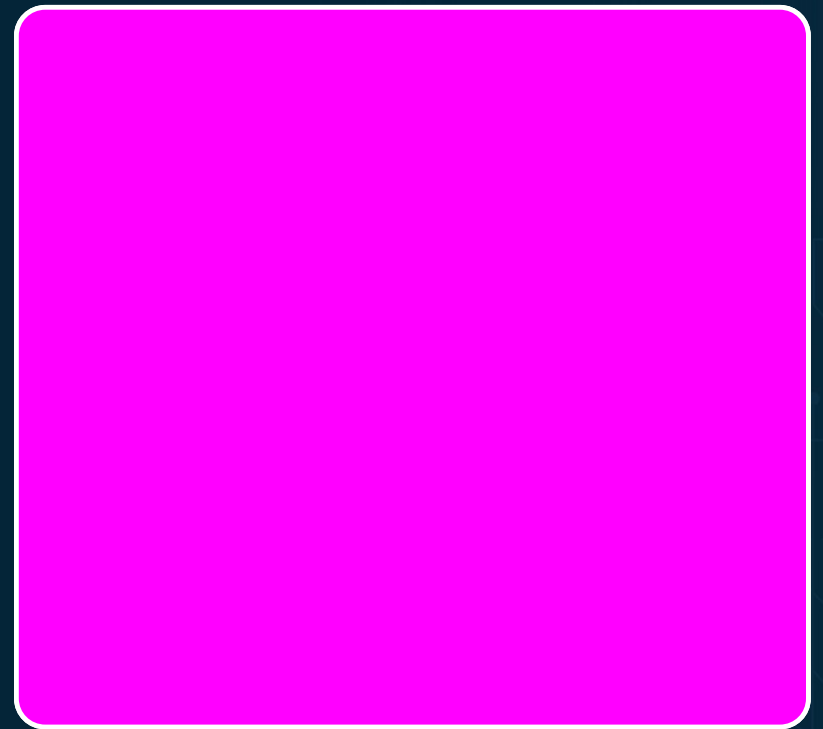
High-volume requests inflate spend

No breach needed — purely economic



When Cost Abuse Delays Detection

Slow AI responses, slow incident response
Cost monitoring is a security control



Token Monitoring: Two Modes

PREVENTATIVE

Ceilings block oversize requests

DETECTIVE

Trend analysis flags odd growth



Spotting Automated Abuse



SPEED

Machine-pace
request intervals



BOT-LIKE

Rapid follow-ups
probe prior output



FINGERPRINT

Timing, token
structure, parsing



EVASION

Volume abuse
inside rate limits



Beyond Token Counts

COMPUTE

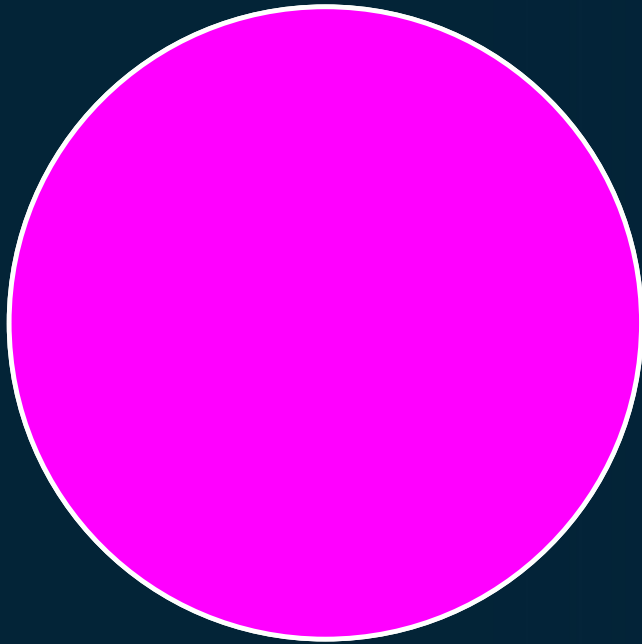
GPU saturation flags
adversarial load

STORAGE

Dataset + embedding
growth watched

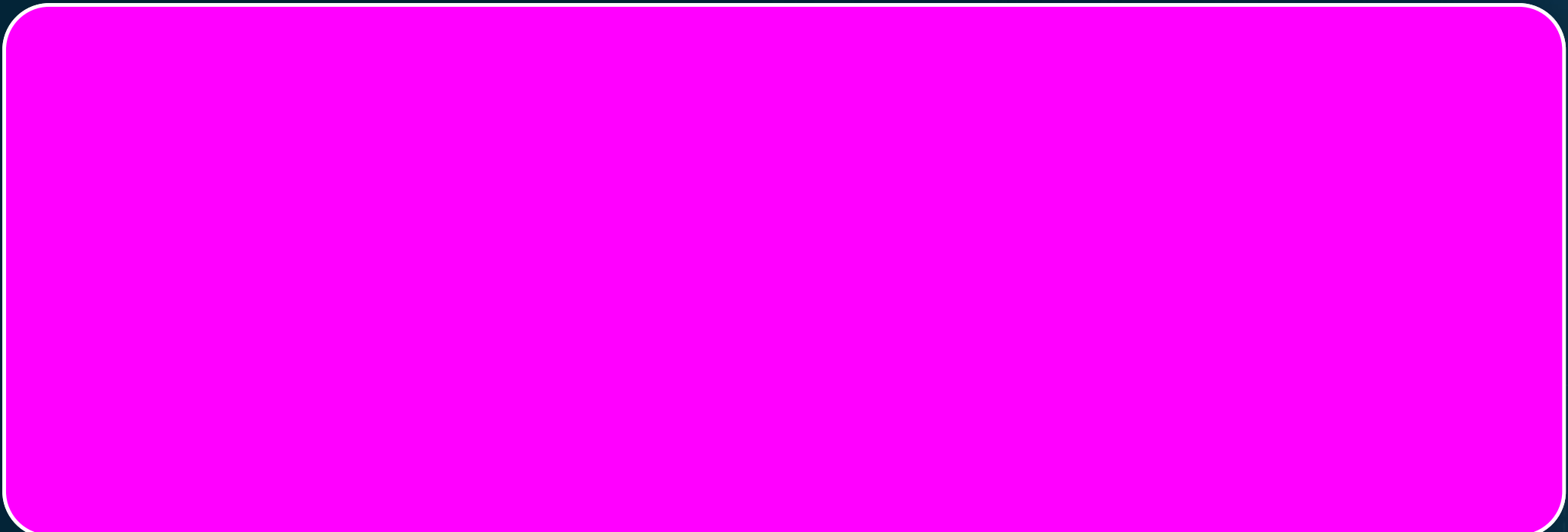
CORRELATE

Tie spikes to identities
and endpoints



Wire Alerts to Action

1. Alert thresholds trigger investigation
2. Throttle dynamically during abuse
3. Post-incident cost analysis refines policy
4. Route to security AND finance



Demo: Resource Abuse Pipeline

Token quotas, cost anomalies, fingerprinting, correlation

Episode Takeaways

Economic DoS — real damage, no data theft

Token controls: preventative ceilings + detective trends

Behavioral detection closes the rate-limit gap

Correlate spikes to identities, not aggregates



AI Cost Monitoring and Resource Abuse

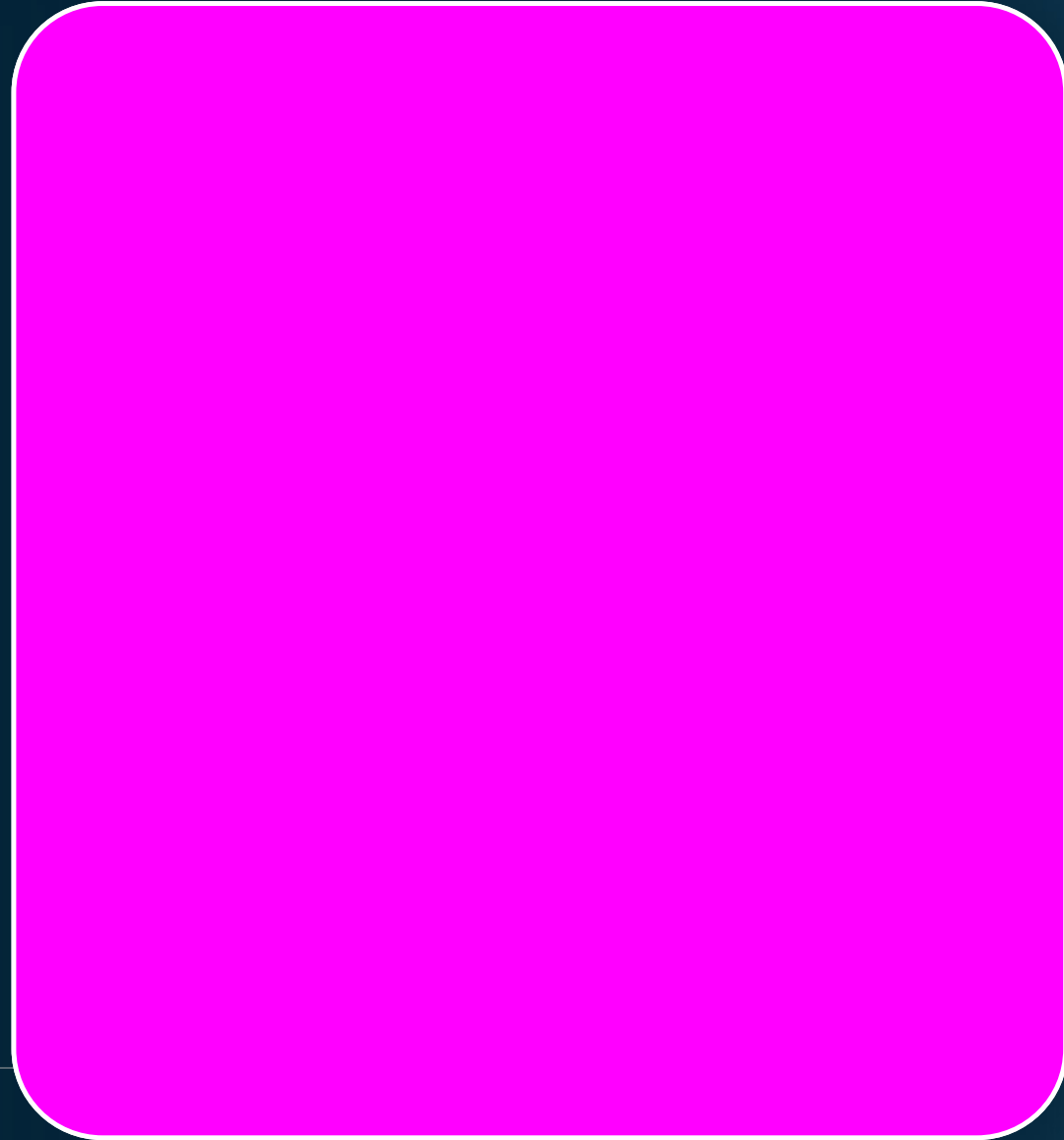
Chapter 09 · Episode 04 · Domain 2.6 — Economic Denial of Service

The Economic Attack Surface

Token billing = attackable cost curve

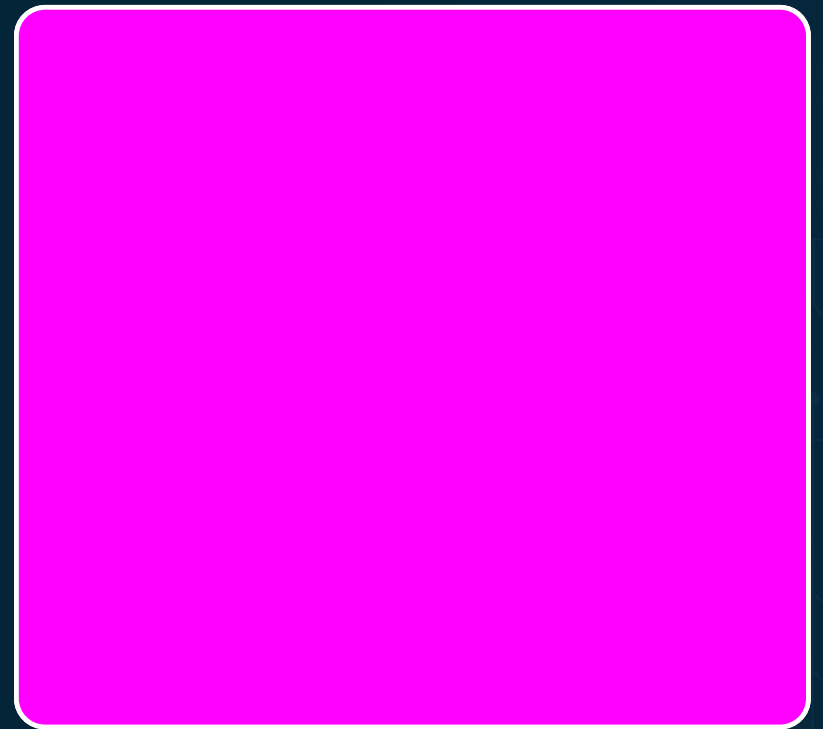
High-volume requests inflate spend

No breach needed — purely economic



When Cost Abuse Delays Detection

Slow AI responses, slow incident response
Cost monitoring is a security control



Token Monitoring: Two Modes

PREVENTATIVE

Ceilings block oversize requests

DETECTIVE

Trend analysis flags odd growth



Spotting Automated Abuse



SPEED

Machine-pace
request intervals



BOT-LIKE

Rapid follow-ups
probe prior output



FINGERPRINT

Timing, token
structure, parsing



EVASION

Volume abuse
inside rate limits



Beyond Token Counts

COMPUTE

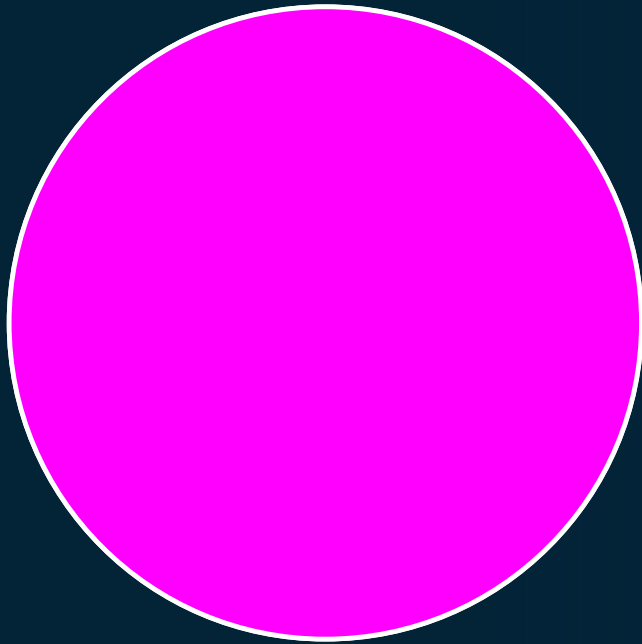
GPU saturation flags
adversarial load

STORAGE

Dataset + embedding
growth watched

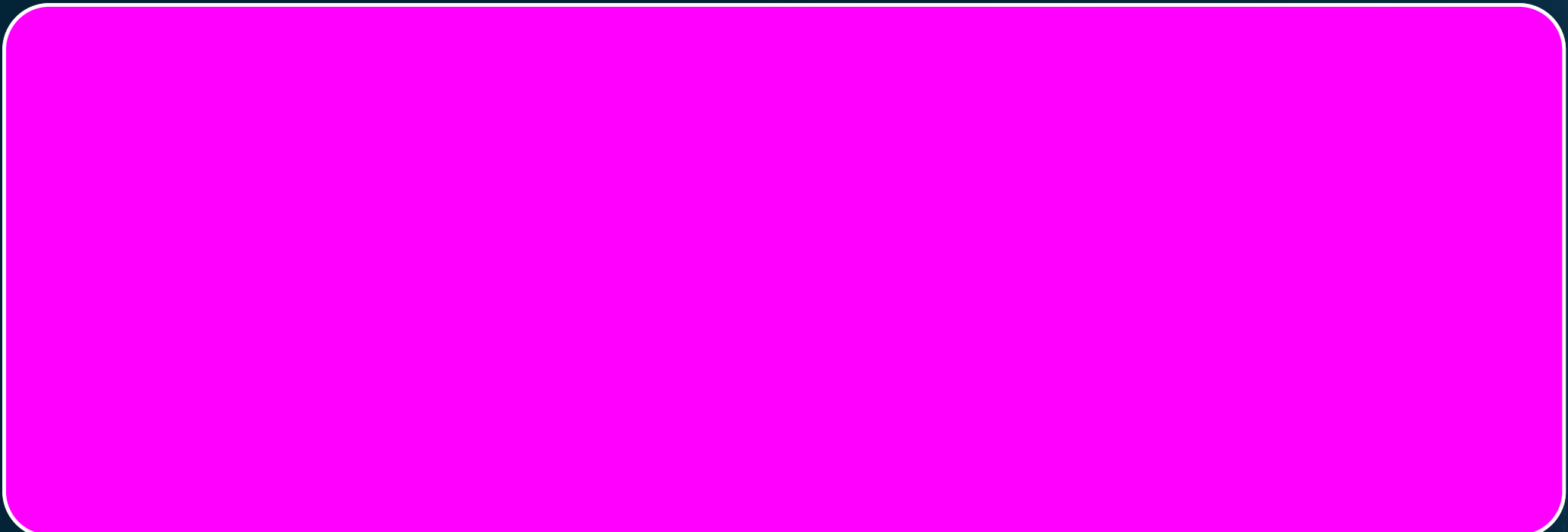
CORRELATE

Tie spikes to identities
and endpoints



Wire Alerts to Action

1. Alert thresholds trigger investigation
2. Throttle dynamically during abuse
3. Post-incident cost analysis refines policy
4. Route to security AND finance



Demo: Resource Abuse Pipeline

Token quotas, cost anomalies, fingerprinting, correlation

Episode Takeaways

Economic DoS — real damage, no data theft

Token controls: preventative ceilings + detective trends

Behavioral detection closes the rate-limit gap

Correlate spikes to identities, not aggregates

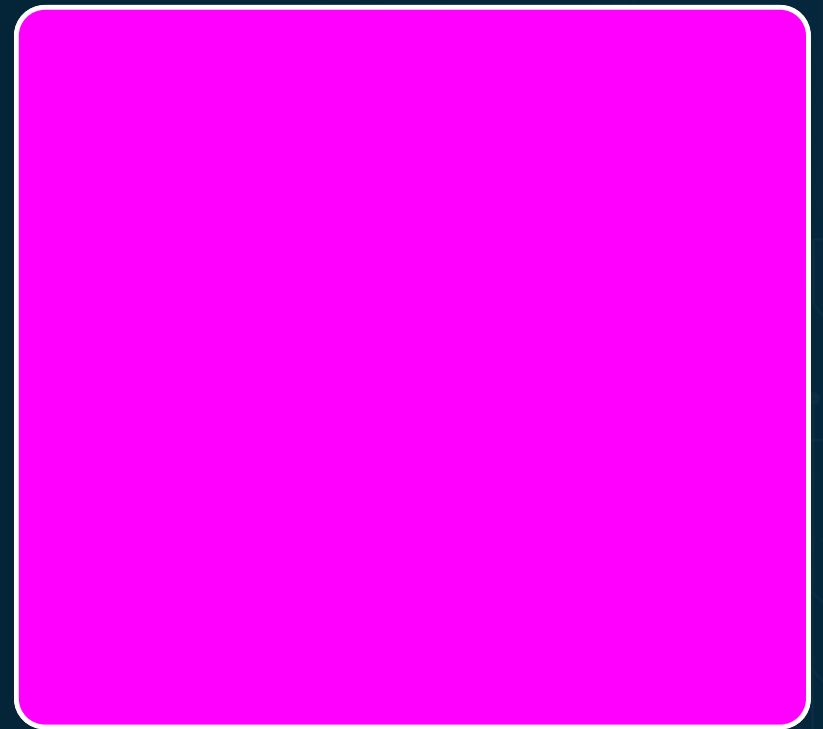
Domain 2 Capstone: Defense in Depth

Chapter 09 · Episode 07 · Domain 2.6 — Layered Remediation

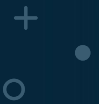
Precision Beats Piling On Controls

Threat → control → layered remediation

Maturity = correct mapping, not volume



Attack-to-Control Mapping



INJECTION

Prompt firewall
+ segmentation



EXTRACTION

Rate limits
+ output restriction



POISONING

Dataset validation
+ ingestion

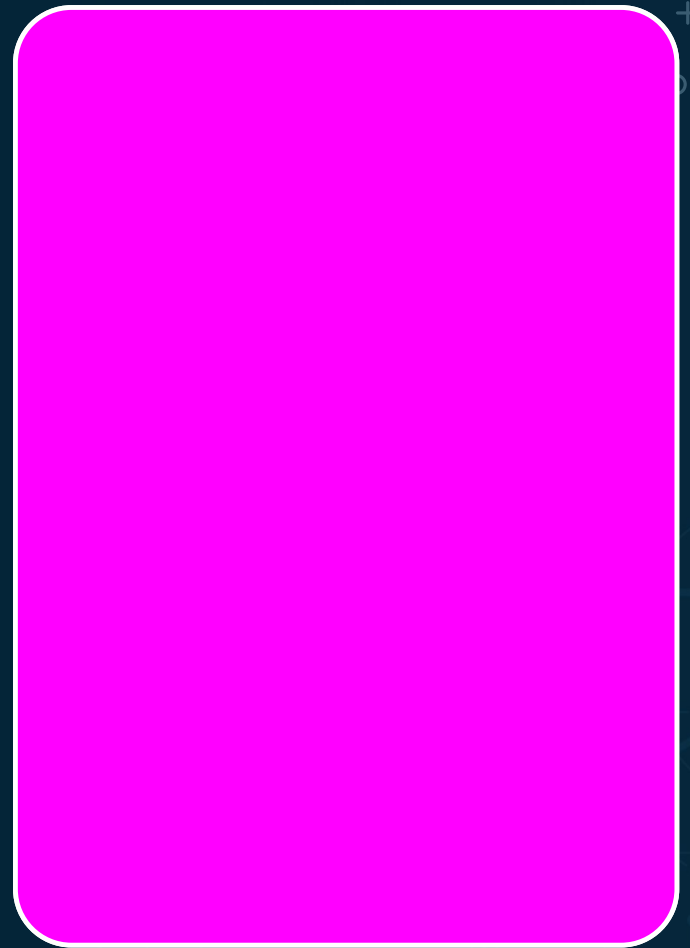


AGENCY

Tool scoping + HITL
+ timed tokens

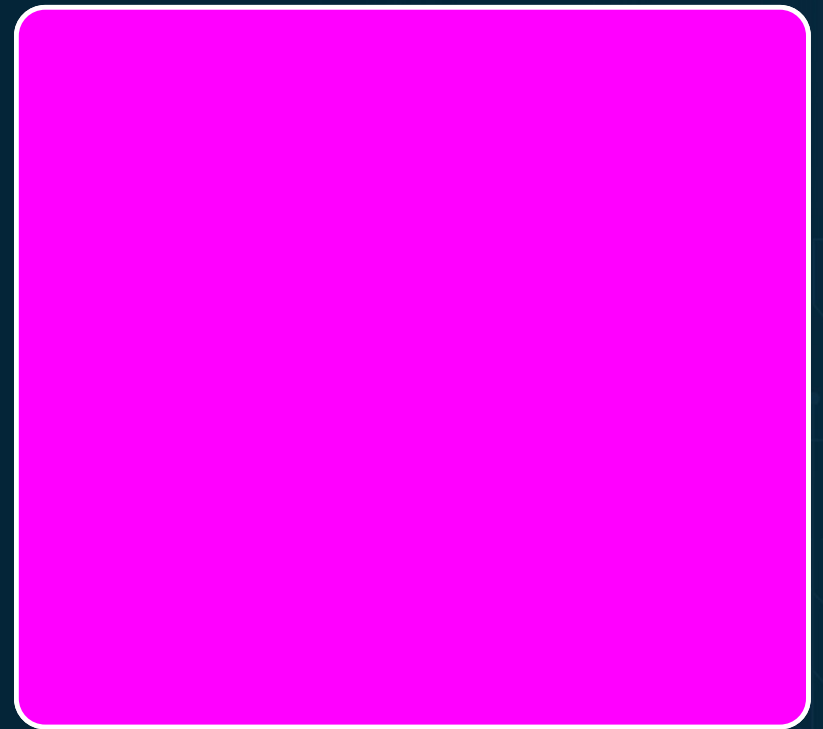
Compensating Controls Buy Time

Backstop when primary controls slip
HITL while firewall rules mature
Temporary — never the architecture



Assume a Layer Will Fail

No single control is infallible
Resilience comes from the stack



Controls at Every Layer



DATA

Encryption,
masking, hashing



INTERFACE

Firewalls, token +
rate limits, auth



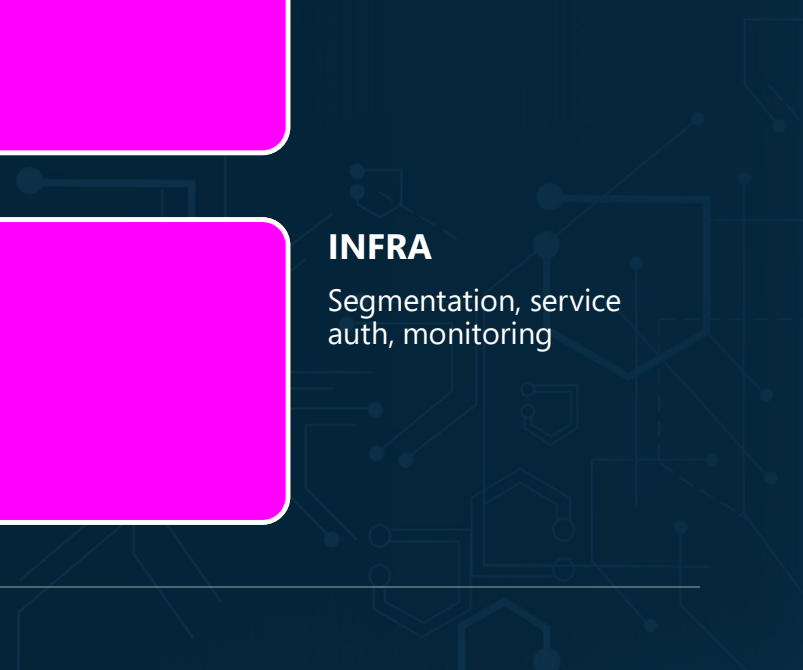
MODEL

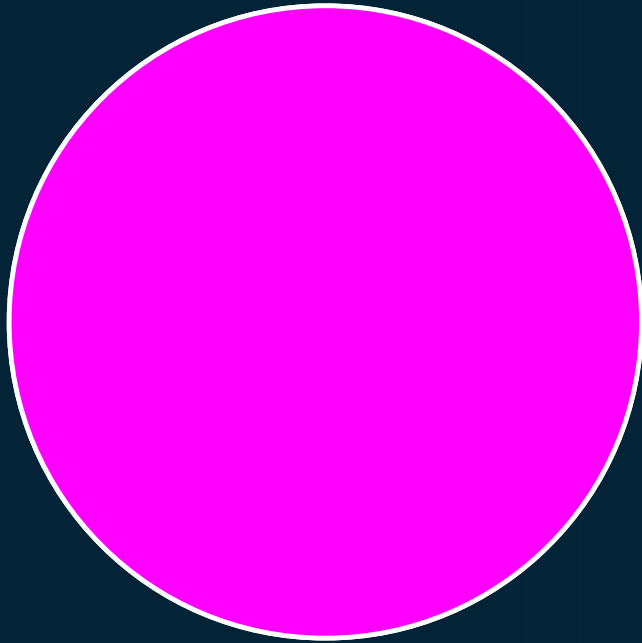
Evaluation +
adversarial training



INFRA

Segmentation, service
auth, monitoring



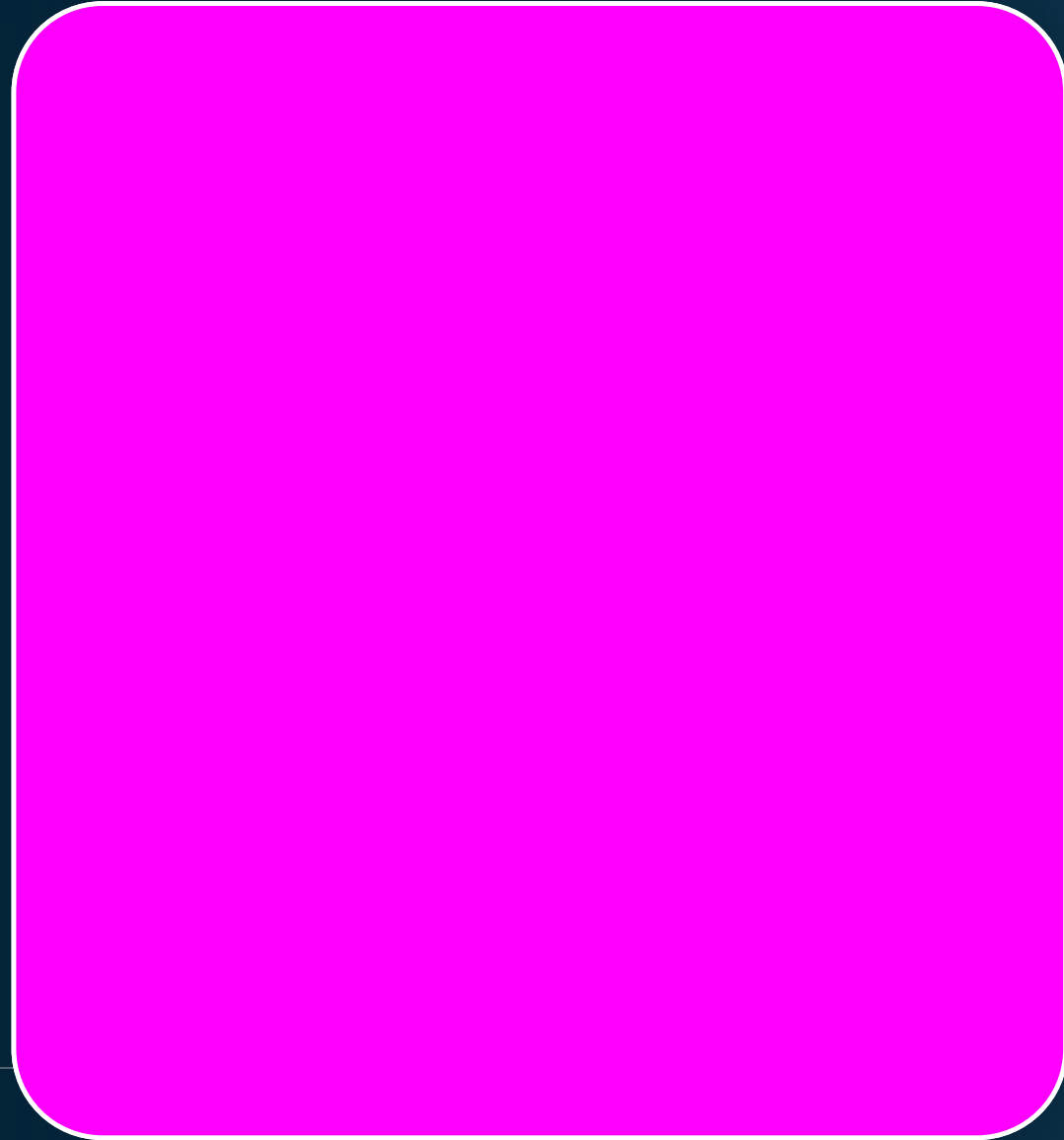


Prioritize by Risk

1. Impact × likelihood guides effort
2. High-value assets protected first
3. Capacity goes to consequential exposure
4. Reassess as threats evolve

Domain 2, Assembled

Modeling → taxonomy → rails → access
Encryption, data safety, monitoring
One coordinated, layered architecture



Demo: Defense in Depth Drill

Scenario → vector + layer → gaps → compensating controls

Episode Takeaways

Vector-to-control mapping is the top-tested skill

Misaligned remediation = testable wrong answer

Compensating controls buy time, not safety

Layer → control category → layered remediation

